SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A1-Threat Intelligence Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	5 (all compulsory)	**Marks per Question**	10
Reg. No		**Name**	
Faculty	Dr.V.Parthipan	**Slot**	A

Instructions: Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.

CO3: Perform threat analysis using intelligence models and utilize industry tools for monitoring and detection.

Code of Conduct:

I G. Aswartha Manidheep(192425089) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

G. Aswartha Manidheep

Signature of Student

Questions :

1. **Threat Hunting Techniques:** An organization suspects that an attacker has gained unauthorized access to its internal network. The security team observes unusual login times, unexpected processes, and connections to unfamiliar external servers. Describe the proactive threat-hunting techniques you would use to investigate the activity and identify potential threats. [10]

2. **SIEM Tools and Security Monitoring :** A company implements a Security Information and Event Management (SIEM) system to monitor its network. The system generates multiple alerts about suspicious login attempts and unusual outbound connections. Explain how the SIEM system can collect and analyze security events, correlate alerts, and help security analysts prioritize potential threats. [10]
3. **Security Monitoring and Anomaly Detection:** A company's security monitoring dashboard identifies a sudden increase in outbound network traffic during non-working hours. The activity originates from a database server that normally transfers only small amounts of data. Explain how you would investigate the anomaly, identify possible data exfiltration, and recommend suitable monitoring and prevention measures. [10]
4. **Tools Used in the IT Industry for Threat Hunting:** An IT organization suspects that malware has infected several employee workstations. The security team has access to SIEM software, endpoint detection tools, network traffic analyzers, and vulnerability scanners. Select suitable tools for investigating the incident and explain how each tool can help identify, analyze, and contain the threat. [10]
5. **Integrated Threat Hunting and Incident Reporting:** A company detects suspicious user logins, connections to a malicious domain, and an unknown process running on an employee workstation. The security team uses Splunk or the ELK Stack to analyze logs and a threat intelligence platform to verify suspicious indicators. Describe the complete threat-hunting process, including data collection, log correlation, threat investigation, malware analysis if required, risk assessment, and preparation of a threat-hunting report with recommended remediation actions. [10]

ANSWERS

CSA6303 – Threat Intelligence and Network Security | A1 – Threat Intelligence Report (CO3)

Q1. Threat Hunting Techniques [10 Marks]

Threat hunting is the proactive, analyst-driven search through networks, endpoints and logs for attackers who have bypassed automated defences. Here the symptoms are unusual login times, unexpected processes and connections to unfamiliar external servers, so the hunt starts from a hypothesis.

Step 1 – Form a hypothesis

"An attacker has stolen valid credentials, is logging in outside working hours, running a malicious process and communicating with a command-and-control (C2) server." The hypothesis is mapped to MITRE ATT&CK techniques (Valid Accounts T1078, Command and Scripting Interpreter T1059, C2 over application-layer protocols T1071).

Step 2 – Hunting techniques

Technique	What the hunter does	Finding it can reveal
Hypothesis-driven hunting	Tests the ATT&CK-based hypothesis against logs and endpoint data	Evidence of the attacker's tactics at each stage
IoC-based (intel-driven) hunting	Searches for known malicious IPs, domains, file hashes and URLs from threat feeds	Matches with known malware or attacker infrastructure
Behavioural / anomaly hunting	Compares activity to a baseline: login times, volume, rare processes	Off-hours logins, impossible-travel logins, abnormal data transfer
Log and authentication analysis	Reviews Windows event IDs 4624/4625 (logon), 4672 (privileged logon), VPN and AD logs	Brute force, password spraying, use of stolen accounts, lateral logins
Process and endpoint hunting	Uses EDR to examine process trees, parent-child relationships, PowerShell/cmd use, new services and scheduled tasks, persistence keys	Unexpected processes, living-off-the-land tools, persistence
Network traffic hunting	Analyses NetFlow, DNS and proxy logs and packet captures for beaconing, rare destinations, long DNS names and unusual ports	C2 communication, data exfiltration, DNS tunnelling
Stack counting / frequency analysis	Counts occurrences of processes, domains or user agents and inspects the rarest	Outliers that blend into normal noise

Step 3 – Investigation workflow

- **Scope:** list the affected user accounts, hosts and time window from the alerts.
- **Collect:** gather authentication logs, EDR telemetry, DNS/proxy/firewall logs and memory/disk artefacts from suspect hosts.
- **Analyse:** check the unfamiliar external IPs/domains on VirusTotal and threat intelligence feeds; hash the unknown processes and check their parent process and file path.

- **Pivot:** use each finding (a hash, IP, account) to search for the same indicator on other hosts to find lateral movement.
- **Contain:** isolate infected hosts, disable compromised accounts, block malicious IPs/domains at the firewall.
- **Document and improve:** record findings, create new detection rules (SIEM/EDR) and update the baseline.

Tools: Splunk/ELK, Microsoft Defender/CrowdStrike (EDR), Wireshark/Zeek, Sysmon, Velociraptor and MITRE ATT&CK Navigator.

Q2. SIEM Tools and Security Monitoring [10 Marks]

A **SIEM (Security Information and Event Management)** system collects, normalises, stores and analyses log data from across the organisation in real time and raises alerts about suspicious activity. Examples: Splunk, IBM QRadar, Microsoft Sentinel, ArcSight, Elastic SIEM.

1. Event collection

- Log sources: firewalls, routers, IDS/IPS, servers, Active Directory, VPN, endpoints/EDR, antivirus, applications and cloud services.
- Collection methods: agents/forwarders, syslog, APIs and WMI.
- Collected data is **parsed and normalised** into a common format (timestamp, source, user, action) and stored centrally for search and compliance.

2. Analysis

- Rule-based detection (e.g., "more than 5 failed logins in 2 minutes").
- Baselining and **UEBA/anomaly detection** (e.g., a user logging in at 3 a.m. from a new country).
- Enrichment with **threat intelligence** (known malicious IPs/domains) and asset/user context.

3. Correlation of alerts

Correlation links related individual events into one meaningful incident. In this scenario:

```
Many failed logins (user A)  ->  successful login at 2 a.m.
        ->  new process started on host  ->  outbound connection
        to unknown IP  ==>  ONE high-severity incident:
        "Possible account compromise with C2 / exfiltration"
```

Without correlation, these would be separate low-level alerts that analysts might ignore.

4. Prioritisation

Factor	How it helps prioritise
Severity / risk score	Combined score of correlated events; multiple stages of attack raise priority
Asset criticality	Alerts on servers or databases rank higher than on test machines
Threat intelligence match	Connection to an IP known to be malicious becomes high priority
User privilege	Alerts involving admin or executive accounts are escalated
False-positive suppression	Whitelists and tuning remove noise so analysts focus on real threats

5. Response and reporting

- Dashboards and real-time alerts, automatic ticket creation and integration with **SOAR** for automated blocking or isolation.

- Investigation by analysts (drill down into raw logs), plus compliance reports and an audit trail.

Q3. Security Monitoring and Anomaly Detection [10 Marks]

A database server that normally sends only small amounts of data is sending large outbound transfers outside working hours – a strong indicator of possible **data exfiltration**.

A. Investigation steps

- **Validate the alert:** confirm it is not a scheduled backup, replication or maintenance job (check change tickets and the backup schedule).
- **Identify the destination:** find the external IPs/domains, check reputation (VirusTotal, threat feeds, WHOIS, geolocation) and see whether they are known or new.
- **Analyse the traffic:** use NetFlow, firewall and proxy logs and packet capture (Wireshark/Zeek) to check volume, protocol (FTP, HTTPS, DNS tunnelling, cloud storage), ports and whether data is encrypted or compressed.
- **Examine the server:** review running processes, new scheduled tasks, services, scripts and unknown executables (via EDR); check database audit logs for large `SELECT`/export queries and which accounts ran them.
- **Review authentication:** look for off-hours logins, new or privileged accounts, and logins from unusual IPs (possible compromised credentials or insider).
- **Scope the damage:** identify which tables/records were accessed (customer data, PII, financial) and whether other hosts talk to the same destination.

B. Indicators of data exfiltration

- Large or sustained outbound transfers at odd hours from a host that rarely sends data.
- Connections to rare, newly registered or foreign destinations; beaconing patterns.
- Large archives (zip/rar) created, unusual database dumps, high DNS query volume with long names.
- Use of unapproved tools (rclone, FTP, cloud sync) or privilege escalation before the transfer.

C. Immediate containment

- Isolate the server or block the destination IP at the firewall (while preserving evidence – memory and disk images).
- Disable or reset suspected accounts and keys, and engage the incident response team; notify legal/management if personal data was exposed.

D. Monitoring and prevention measures

Measure	Purpose
SIEM alerts and UEBA baselining	Alert on outbound volume or time deviations for critical servers
Data Loss Prevention (DLP)	Inspect and block sensitive data leaving the network
Network segmentation and egress filtering	Database servers allowed to talk only to specific internal hosts; deny direct internet access
Database activity monitoring (DAM)	Log and alert on bulk queries and exports
Least privilege and MFA	Limit who can access/export data; reduce credential theft impact

Encryption of data at rest and in transit	Stolen data is of little use
EDR, IDS/IPS and DNS monitoring	Detect malware and tunnelling; block known C2 destinations
Regular patching, audits and staff training	Reduce the vulnerabilities attackers and insiders can exploit

Q4. Tools Used in the IT Industry for Threat Hunting [10 Marks]

Suspected malware on several workstations is best handled by combining the four tool categories available, each covering a different stage of the response.

Tool category (examples)	Identify	Analyse	Contain
SIEM (Splunk, QRadar, Sentinel)	Correlates logs from all workstations; finds common alerts, user accounts and malicious IPs; spots the first infected host	Timeline of events, searches across all hosts for the same IoCs, enrichment with threat intelligence	Triggers alerts and SOAR playbooks (disable account, block IP/domain)
EDR (CrowdStrike, Defender for Endpoint, SentinelOne)	Detects malicious processes, file hashes and persistence on endpoints	Process tree, command lines, registry/file changes, memory artefacts, remote forensic collection	Network-isolates infected workstations, kills processes, quarantines files, rolls back changes
Network traffic analyser (Wireshark, Zeek, NetFlow)	Finds beaconing, connections to malicious IPs/domains and unusual protocols	Packet and DNS inspection, payload and C2 behaviour, volume of data sent	Provides IPs/domains/ports for firewall, proxy and DNS blocking
Vulnerability scanner (Nessus, OpenVAS, Qualys)	Detects missing patches and weak configurations that the malware exploited	Finds other workstations exposed to the same vulnerability and the likely entry point	Drives patching and hardening to stop reinfection and spread

Supporting tools

- **VirusTotal / sandbox (Cuckoo, Any.Run):** analyse suspicious files and URLs safely.
- **Threat intelligence platform (MISP, OTX):** verify IoCs.
- **Antivirus/AV and Sysmon:** scan and log host activity.

How they work together

```
SIEM (detect + correlate) -> EDR (investigate host, isolate)
   -> Network analyser (confirm C2, block) -> Scanner (find root
      cause, patch)  -> re-scan and monitor
```

Q5. Integrated Threat Hunting and Incident Reporting [10 Marks]

The scenario shows three indicators: suspicious logins, connections to a malicious domain and an unknown process. The complete hunt (using Splunk/ELK plus a threat intelligence platform) follows these stages.

1. Data collection

- Forward logs to Splunk/ELK: Windows event logs, Sysmon, EDR, AD/VPN, DNS, proxy, firewall and email logs.
- Preserve evidence from the workstation (disk and memory image, process list) with chain of custody.

2. Log correlation

- Search the suspicious user's logins (time, source IP, failures followed by success) and correlate with the workstation and its process-creation events.
- Join DNS/proxy logs with the process and user to show which process contacted the malicious domain and when.
- Build a timeline: login -> process execution -> domain connection -> any lateral movement.

```
Example Splunk-style search:
index=dns OR index=proxy dest_domain="bad-domain.com"
| stats count by src_ip, user, process_name, _time
```

3. Threat investigation / verification

- Check the domain, IPs and file hash on the **threat intelligence platform** (MISP, VirusTotal, AlienVault OTX) for known malware family and campaign.
- Map behaviour to MITRE ATT&CK, and hunt for the same IoCs on other hosts to find the scope.

4. Malware analysis (if required)

- **Static analysis:** file hash, strings, imports, packer detection.
- **Dynamic analysis:** run in a sandbox to observe file, registry and network activity, persistence and C2.
- Extract new IoCs (hashes, domains, mutexes) and create detection rules.

5. Risk assessment

Factor	Assessment
Confirmed compromise?	Verified by IoC matches and malicious behaviour
Asset and data impact	Sensitivity of the workstation, user privileges and data accessed
Spread	Number of other hosts/accounts affected
Severity rating	Low / Medium / High / Critical based on likelihood × impact

6. Containment, eradication and recovery

- Isolate the workstation, disable/reset credentials, block the domain and IPs at the firewall/DNS.
- Remove the malware, patch vulnerabilities, reimage if needed, then restore and monitor closely.

7. Threat-hunting report

Report section	Content
Executive summary	Overview of what happened, impact and current status
Scope and methodology	Hypothesis, data sources, tools and timeframe
Findings and timeline	Evidence, affected users/hosts and sequence of events
IoCs and ATT&CK mapping	Hashes, IPs, domains, processes and techniques observed
Risk and impact assessment	Severity, data exposed and business impact
Remediation actions	Containment, eradication and recovery steps taken/required
Recommendations	New SIEM/EDR detection rules, patching, MFA, user training, network segmentation, regular hunts and lessons learned